OAUTH REDIRECT URI HIJACKING

> System Exploit Profile: Unauthorized Authentication Bypass

[FEYNMAN-STYLE EXPLAINER // VERSION 3.0]

PHASE 1: THE CORE MECHANISM

Decoding the GPS of Modern Authentication

THE GPS OF AUTHENTICATION

REDIRECT URI LOGIC

In OAuth, the `redirect_uri` is the specific location where the login result (code or token) is sent after validation.

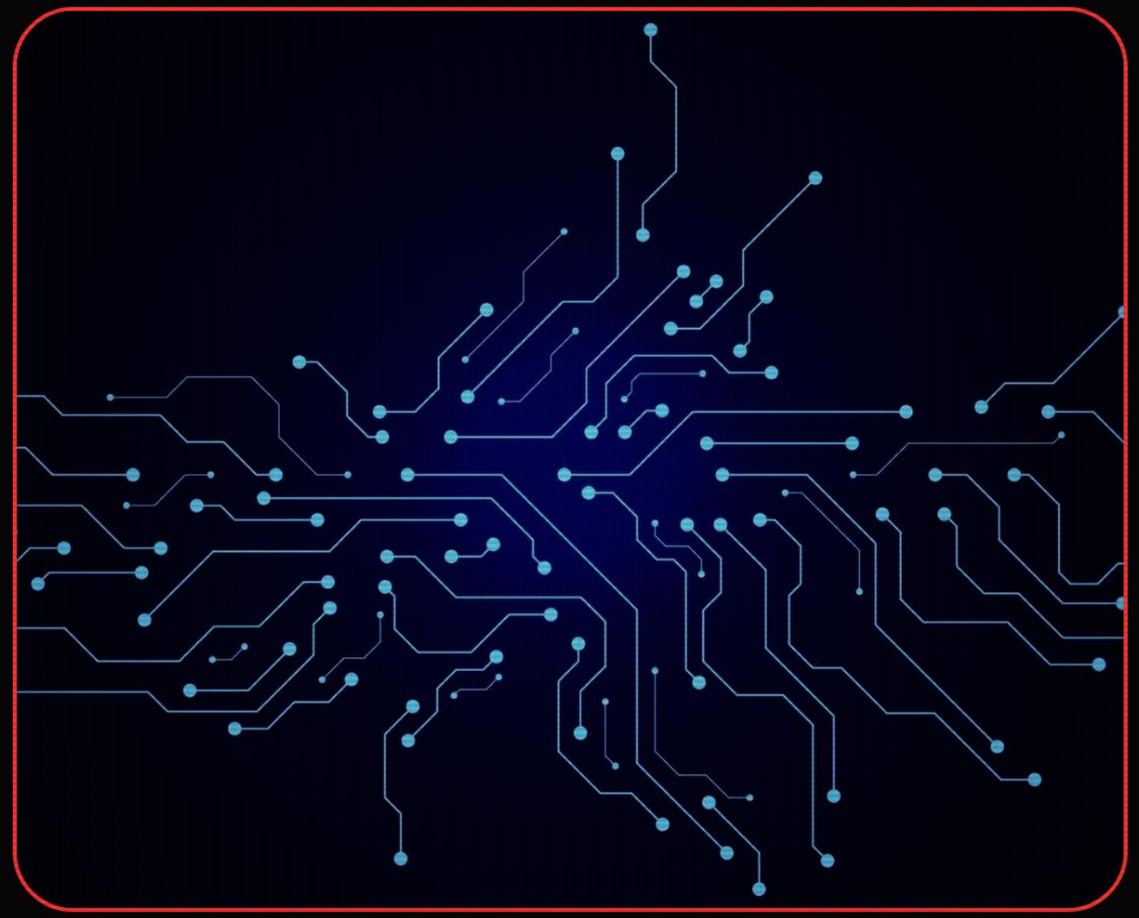
Think of it as the **Destination GPS** for your sensitive credentials.

THE SECURITY LAYER

To stay safe, the server maintains a **Whitelist**. This is a restricted list of trusted URLs.

Rule: **"Only send data to these pre-approved endpoints."**

THE ROOT ISSUE: LOOSE VALIDATION



SYSTEMIC FAILURE

Vulnerabilities emerge when servers perform **loose pattern matching** instead of exact, byte-for-byte verification.

- Checking only the **beginning** of the URL.
- Allowing **extra paths** or parameters.
- Mishandling **URL parsing** logic.

THREAT ALERT:

Malicious URLs can pass validation while carrying payloads to attacker-controlled domains.

PHASE 2: ATTACK VECTORS

Bypassing Whitelists via Logic Manipulation

COMMON BYPASS TECHNIQUES

SUBDOMAIN TRICK

Attacker appends their domain as a suffix: `trusted.com.evil.com`. Poor filters only see the prefix.

PATH TRAVERSAL

Using `/../` to exit the whitelist path: `trusted.com/callback/../evil`.

PARAMETER CHAINING

Nesting redirects: `trusted.com?redirect=evil.com`. The server trusts the first hop.

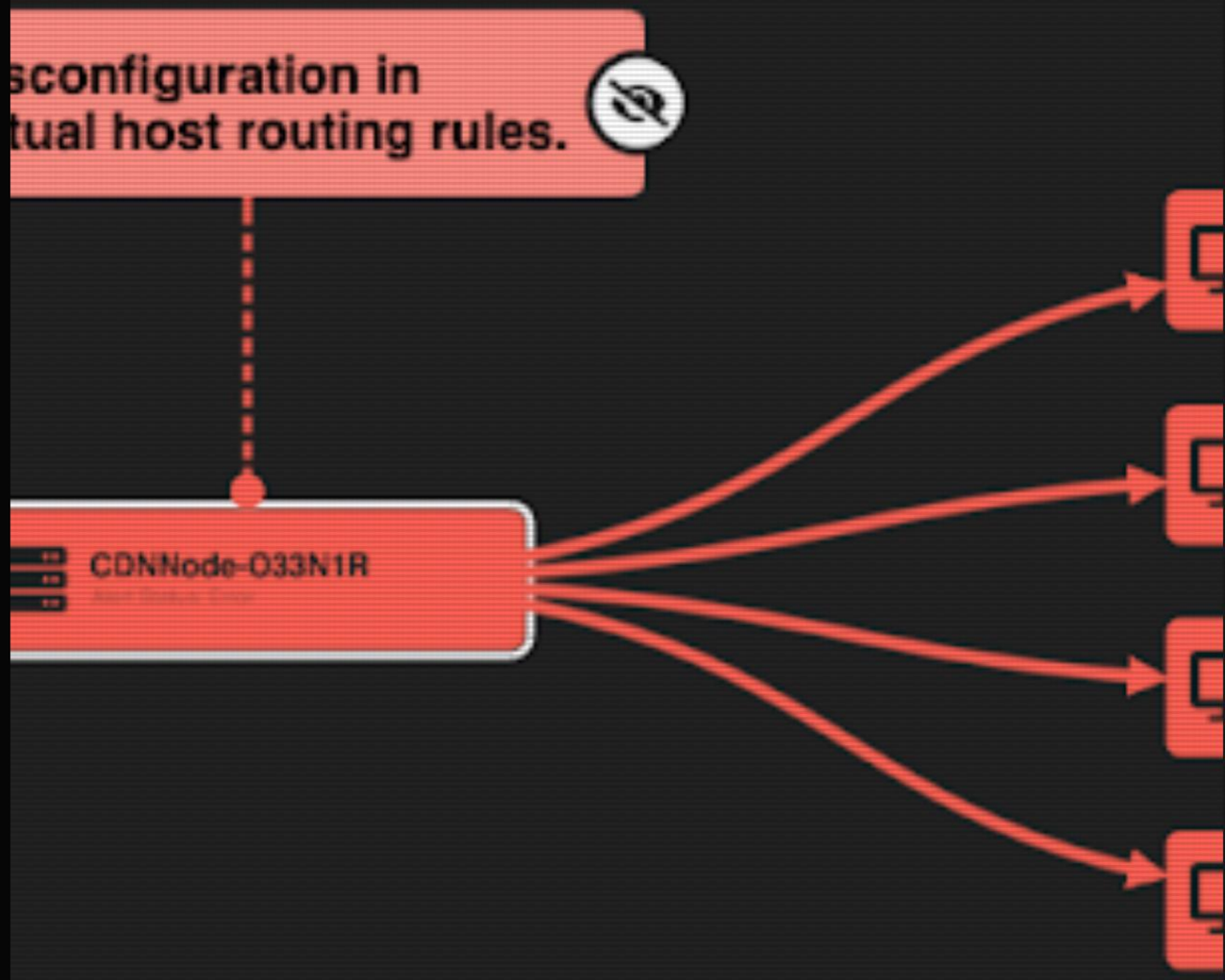
CHAINING VULNERABILITIES

The most lethal exploits combine **Weak Validation** with another bug inside the trusted site, such as an **Open Redirect**.

Example Flow:

1. OAuth sends token to `trusted.com/page`
2. That page has a redirect bug to `evil.com`
3. Token is forwarded automatically to the attacker.

Result: Full token exfiltration via a "trusted" intermediate hop.



EXPLOIT EXECUTION FLOW

01

CRAFT

Attacker creates a malicious OAuth link with manipulated URI.

02

BYPASS

Victim logs in; OAuth server "approves" the spoofed URI.

03

EXFILTRATE

Code/Token is sent to attacker's server logs.

04

TAKEOVER

Attacker injects the code into the app and logs in as victim.

THE ATTACKER'S PHILOSOPHY

"If the security guard only looks at the front of the pass, the door is already open."

— SYSTEM INTRUSION LOGIC

IMPACT COMPLEXITY COMPARISON

Note: Authorization Code theft is harder to execute but provides deeper access than simple Implicit Flow token leaks.

THE MITIGATION PLAYBOOK

Bypass Vector	Weak Defense	STRICT MITIGATION
Subdomain / Prefix	Starts-with check	Exact String Match (1:1)
Path Traversal	Regex path check	Pre-registered Whitelist Only
Open Redirect Chain	Trusting internal domain	Disallow query params in URI
Token in URL Fragment	Implicit Flow	Use Auth Code Flow + PKCE

TERMINATION SEQUENCE

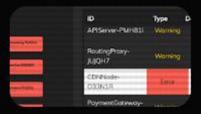
Questions for the Research Team?

ROOT_TAKEAWAY: If redirect_uri validation is not strict and exact, the session is already compromised.

IMAGE SOURCES

https://static.vecteezy.com/system/resources/previews/075/617/718/non_2x/wide-cyber-security-and-network-connection-concept-futuristic-circuit-board-technology-texture-on-dark-blue-background-vector.jpg

Source: www.vecteezy.com



https://cambridge-intelligence.com/wp-content/uploads/2025/07/hierarchy-graph-impact-alerts-it-network-infrastructure.png

Source: cambridge-intelligence.com

---

https://png.pngtree.com/background/20240112/original/pngtree-abstract-data-matrix-3d-rendering-of-green-coding-and-hacking-concept-picture-image_7228195.jpg

Source: pngtree.com